

ADLYTIC_MASTER_ARCHITECT_AUDIT_2026 — Second Pass

Document type: Production-grade master architecture audit (second pass) Repository: /Users/aliahned/Downloads/adlytic Branch audited: feat/horizontal-scaling Audit date: 2026-06-30 Baseline comparison: First pass ADLYTIC_MASTER_ARCHITECT_AUDIT_2026.md (commit 05752ef) Stack reality: Hono + @hono/node-server, Prisma 7 + PostgreSQL (@prisma/adaptor-pg + pg.Pool), server-rendered TypeScript HTML pages (layout.ts, *Page.ts), inline SHARED_JS, background workers in-process (serve.ts) with optional BullMQ (src/lib/queue.ts), Meta Graph API client, Stripe billing, Claude AI layer, optional Redis (src/lib/redis.ts) NOT Next.js — no React SSR, no App Router, no Vercel edge functions

Scope: Full codebase review across five pillars. Delta focus: commits 64f080e !' 32cd337 on feat/horizontal-scaling (Redis substrate, Redis debounce/token-health cache, BullMQ Phase 3-a, cross-workspace hijack guard, queue-stats CLI, Redis scaling drill).

Commits reviewed through: 32cd337 (queue stats CLI), e6ef331 (BullMQ + R-1 hijack fix + drill), 25aafa0 (Redis debounce + token-health cache), 64f080e (Redis substrate), plus inherited baseline through 885f009 / f7b85af / 26858ed.

Executive Summary

Since the first pass (05752ef), the team shipped a horizontal-scaling infrastructure layer on feat/horizontal-scaling: optional Redis (src/lib/redis.ts), feature-flagged BullMQ queues (BULLMQ_ENABLED, default false), Redis-backed Meta webhook debounce (WEBHOOK_REDIS_DEBOUNCE_ENABLED, default false), read-through token-health cache (cachedTokenHealth.ts), and a cross-workspace AdAccount hijack guard (findExistingAdAccountForWorkspace !' 409 AD_ACCOUNT_ALREADY_LINKED_ELSEWHERE).

Defaults preserve first-pass behavior. With flags off and REDIS_URL unset, the API path matches the pre-scaling codebase: in-process setImmediate, in-memory OAuth sessions, in-memory rate limits, and auto-sync calling worker.sync() directly.

Three production-critical structural risks from the first pass remain materially unchanged:

1. Session-scoped Postgres advisory locks + Prisma connection pooling — syncChunked retains the pg_advisory_unlock_all() preflight (f7b85af / Fix C-1). sync() (auto-sync path in serve.ts:204) still acquires locks without that preflight. Auto-sync was not migrated to syncChunked or BullMQ.

1. Background workload coupling — BullMQ exists but is opt-in and Phase 3-a co-locates workers with HTTP in the same Node process (serve.ts:96, workers/queue/index.ts:7-11). Auto-sync, token refresh, raw-insight pruning, rollup refresh, and (when flags off) webhook reconciles still share one event loop and one Prisma pool. Enabling BullMQ adds up to 12 concurrent queue jobs (2+2+4+4) on the same process.

1. Multi-instance deployment gaps — Post-callback OAuth sessions remain in-memory (oauthSessions Map, server.ts:189). Rate-limit maps, platform-stats cache, and coarse auto-sync lock remain per-process. Redis debounce and token-health cache reduce *some* split-brain symptoms when REDIS_URL is set, but webhook reconcile winners still fire via in-process setTimeout (metaWebhook.ts:190-191), and OAuth completion still requires sticky sessions or single replica.

Positive deltas since first pass:

- Cross-workspace Meta ad account hijack on reconnect is now explicit 409 instead of silent workspaceId overwrite (server.ts:404-427, three connect sites guarded).
- BullMQ enqueueOrFallback pattern ensures no work loss when Redis/queue fails — falls back to original setImmediate bodies (queue.ts:201-217).
- Meta webhook POST can enqueue payload durably when BULLMQ_ENABLED=true (server.ts:1214-1223).
- Token-health probe uses 60s Redis read-through cache when Redis is available (cachedTokenHealth.ts, wired at server.ts:1328).
- Graceful SIGTERM drains BullMQ workers before disconnect (serve.ts:297-305).

- Phase 6a workspace-isolation audit documented in WORKSPACE_ISOLATION_CHECKLIST.md; R-1 remediated in e6ef331.

Overall verdict: Shippable for early production / controlled beta on a single Railway instance — unchanged from first pass. The horizontal-scaling branch adds foundation code behind feature flags but does not, at default configuration, resolve the first pass's P0 items (R1–R5). Enabling flags without addressing advisory-lock semantics on the auto-sync path and OAuth session persistence leaves multi-replica deploys partially hardened at best.

Audit Methodology

Step | Action

- 1 | Re-read first pass findings R1–R15 and pillar items P1-01–P5-17
- 2 | `git log 05752ef..HEAD` and `git diff 05752ef..HEAD --stat` on `feat/horizontal-scaling`
- 3 | Trace new paths: Redis withRedis, BullMQ `enqueueOrFallback`, `kickoffInitialSync`, `findExistingAdAccountForWorkspace`
- 4 | Re-verify unchanged critical paths: `sync()` vs `syncChunked`, `serve.ts` `auto-sync`, `oauthSessions`, Prisma indexes
- 5 | Cross-reference WORKSPACE_ISOLATION_CHECKLIST.md (Phase 6a)
- 6 | Count : any / as any in `src/` (31 occurrences, unchanged)

Severity scale: identical to first pass (Critical / High / Medium / Low).

Pillar 1 — Architectural Patterns & Code Quality

1.1 System topology (as-built, second pass)

```
Browser % % %° Hono (server.ts) % % %° Prisma/pg.Pool % % %° PostgreSQL
% % %° %²
% % %° %
% % % SSR pages (*Page.ts + layout.ts SHARED_JS)
% % % REST /api/*
% % % [optional] Redis singleton (lib/redis.ts)
% % % [optional] BullMQ dedicated ioredis (lib/queue.ts)
% % % background (flag-dependent):
% % %   setImmediate OR BullMQ workers (in-process, serve.ts:96)
% % %   syncChunked / sync / runEngines / runBrainOrchestrator
% % %   processMetaWebhookEvent (debounced)
% % %   kickoffInitialSync (lib/initialSync.ts)

serve.ts
% % % Recursive setTimeout auto-sync loop (6h) — still calls worker.sync()
% % % refreshExpiringMetaTokens, prune, rollups (unchanged)
% % % Coarse advisory lock: adlytic:auto-sync
% % % bootQueueWorkers() when BULLMQ_ENABLED=true
```

Finding P1-01 — Monolithic route file (worsened) | Medium

`src/api/server.ts` grew from ~3,392 lines (V1) to ~3,486 lines. OAuth hijack guard and BullMQ `enqueue` wiring added net complexity despite extracting `kickoffInitialSync` to `lib/initialSync.ts`.

- Location: `src/api/server.ts:1-3486`
- Delta: +94 lines; route count unchanged structurally; no sub-app split.

Finding P1-02 — Page/API boundary duplicate poll logic | Low | Not fixed

Onboarding in `dashboardPage.ts` still defines a local `pollSyncJob` (lines 1800-1811) instead of exclusively using `window.pollSyncJob`.

- Location: `src/web/pages/dashboardPage.ts:1800-1811` vs `src/web/layout.ts:729-741`, 1168

Finding P1-03 — `getAccount()` assumes single ad account per workspace | High | Not fixed

```
const account = ws.adAccounts[0] ?? null;
```

- Location: `src/api/server.ts:462-467`
- Impact: Unchanged from V1; insertion-order dependent primary account.

Finding P1-04 — TypeScript any usage (31 hits) | Medium | Not fixed

Count unchanged. Same concentration in `getDashboard.ts` (12), `server.ts` (5), `engines`.

Finding P1-05 — Unhandled promise policy: log-only | Medium | Not fixed

serve.ts:42-48 unchanged. BullMQ worker error/failed handlers log only (workers/queue/index.ts:96-102).

Finding P1-06 — process.env reads outside config.ts | Medium | Partially addressed

config.ts now centralizes Redis URL and feature flags (REDIS_URL, BULLMQ_ENABLED, WEBHOOK_REDIS_DEBOUNCE_ENABLED). Direct reads persist for:

- server.ts:270 — ALLOWED_ORIGINS
- server.ts:1065-1068 — Stripe price, PUBLIC_APP_URL
- getDashboard.ts:51,347, claudeClient.ts:21, stripeClient.ts, adminGuard.ts, mockMeta.ts, whatsappLink.ts, runNarrationWorker.ts

Finding P1-07 — Standalone Prisma pool in getDashboard.ts | High | Not fixed

Module-level _pool at getDashboard.ts:60-68 unchanged.

Finding P1-08 — Positive: layer discipline | Strength | Preserved

Meta transport, mappers, repos, engines, dashboard DTO boundary intact.

Finding P1-09 — NEW: Horizontal-scaling code behind default-off flags | Info

Infrastructure exists (redis.ts, queue.ts, four queue processors, drill script) but production-default behavior equals V1:

Flag | Default | Effect when off

REDIS_URL | unset | All Redis paths fall back in-process

BULLMQ_ENABLED | false | No workers; all enqueueOrFallback !' setImmediate

WEBHOOK_REDIS_DEBOUNCE_ENABLED | false | Map-based debounce only

- Location: config.ts:230-255, queue.ts:170-174

Finding P1-10 — NEW: Cross-workspace AdAccount hijack guard | Strength (fix)

findExistingAdAccountForWorkspace returns { kind: 'conflict' } !' 409

AD_ACCOUNT_ALREADY_LINKED_ELSEWHERE. Owned-row updates omit workspaceId to prevent silent transfer.

- Location: server.ts:404-427, guarded at lines 2725-2727, 2848-2850, 3048-3050
- Origin: Phase 6a finding R-1, shipped in e6ef331

Pillar 2 — Concurrency, Locking & Data Integrity

2.1 Advisory lock implementation

Finding P2-01 — Session locks + pooled connections (fundamental) | Critical | Not fixed for auto-sync path

Path | unlock_all preflight | Status

syncChunked() | Yes (syncAccount.ts:1061-1067) | Unchanged from V1

sync() | No (syncAccount.ts:193-195) | Still missing

Auto-sync (serve.ts:204) | Uses sync() | Still vulnerable

Additional facts:

- pg_advisory_unlock_all() blunt-instrument risk unchanged.
- Zero pg_advisory_xact_lock usage (grep confirms).
- No dedicated non-pooled pg.Client for lock holder.
- No SyncJob row-level FOR UPDATE SKIP LOCKED locking.

Finding P2-02 — Advisory lock hash collision | Low | Not fixed

32-bit FNV in advisoryLock.ts:16-22 unchanged.

Finding P2-03 — SyncJob dedupe (Fix A) | Strength | Preserved

Active job reuse at server.ts sync route unchanged.

Finding P2-04 — \$transaction batch size unbounded | High | Not fixed

DailyStatsRepo.upsertMany still wraps all rows in one transaction (dailyStatsRepo.ts:68-94).

Finding P2-05 — Campaign reconcile transaction size | Medium | Not fixed

reconcileCampaignStatuses single \$transaction unchanged.

Finding P2-06 — No deadlock retry | Medium | Not fixed

No 40P01 retry wrapper added.

Finding P2-07 — Crash lock release claim partially true | Medium | Unchanged

Pool/PgBouncer caveats remain; unlock_all mitigates syncChunked symptom only.

Finding P2-08 — Coarse auto-sync lock duration | Medium | Unchanged

adlytic:auto-sync held for full pass including all accounts serially (serve.ts:231-241).

Finding P2-09 — Positive: idempotent upserts | Strength | Preserved

Finding P2-10 — NEW: BullMQ co-located with API (Phase 3-a) | High (when enabled)

When BULLMQ_ENABLED=true, workers boot inside the API process (serve.ts:92-96). Concurrency: sync-account×2, maintenance×4, engines-and-brain×2, reconcile-campaigns×4 = up to 12 parallel jobs sharing the same Prisma pool (default max 10) and event loop.

- Location: workers/queue/index.ts:32-37,65-91

- Note: Auto-sync loop is not enqueued to BullMQ; only user-triggered / webhook / initial-sync paths use enqueueOrFallback.

Finding P2-11 — NEW: reconcile-campaigns-v1 queue scaffolded but unused | Medium

Processor exists (reconcileCampaignsProcessor.ts) and worker boots, but no producer calls queues.reconcileCampaigns.add. Webhook reconcile still uses setTimeout (metaWebhook.ts:190-211).

Pillar 3 — API Resilience & Meta Integrity

Finding P3-01 — Retry policy | Medium | Unchanged

metaClient.ts:212-238 unchanged.

Finding P3-02 — Code 17 handling | Strength | Preserved

Finding P3-03 — Pagination cap (500 pages) | Medium | Unchanged

Finding P3-04 — Token lifecycle | High (managed) | Unchanged

Token refresh query still lacks index on tokenExpiresAt (see P5-10).

Finding P3-05 — Meta webhook signature verification | Strength | Preserved

Finding P3-06 — Meta webhook idempotency (debounce only) | Medium | Partially addressed

Redis path adds cluster-wide first-wins debounce via SET NX EX when WEBHOOK_REDIS_DEBOUNCE_ENABLED=true and Redis healthy (metaWebhook.ts:173-196). Limitations documented in code:

- Winner still schedules reconcile via in-process setTimeout — lost if that process dies before fire (metaWebhook.ts:165-170).

- Flag defaults off; without Redis, behavior identical to V1 Map debounce.

When BULLMQ_ENABLED=true, webhook payload enqueued to maintenance queue (server.ts:1214-1215) — durable receipt, but reconcile scheduling inside processMetaWebhookEvent still debounces via setTimeout/Redis, not BullMQ delayed jobs.

Finding P3-07 — Meta webhook GET handshake | Low | Unchanged

Finding P3-08 — Stripe webhook | Strength | Preserved

Finding P3-09 — Error parsing inconsistency (190 detection) | Medium | Not fixed

Regex in serve.ts:210,218-219; typed check in queue processor syncAccountProcessor.ts:114-116. No centralized isMetaErrorCode.

Finding P3-10 — Invalid breakdown combination handling | Strength | Preserved

Finding P3-11 — OAuth session in-memory | High | Not fixed

oauthSessions Map at server.ts:189 with 30-minute TTL prune unchanged. CSRF OAuthState remains DB-backed contrast.

Finding P3-12 — META_APP_SECRET optional in config | Medium | Unchanged

Finding P3-13 — NEW: Token-health cache without reconnect invalidation | Medium

getCachedWorkspaceTokenHealth caches 60s (cachedTokenHealth.ts:38,75-77). invalidateCachedTokenHealth is defined but never called from OAuth reconnect, token rotation, or Meta 190 handlers (grep: only definition in cachedTokenHealth.ts). After successful reconnect, banner may show stale decrypt-failure state for up to 60s when Redis is up.

Pillar 4 — UI/UX Robustness

Commit 885f009 UI resilience items were in the first-pass baseline; no UI file changes in 05752ef..HEAD diff.

Finding P4-01 — Centralized pollSyncJob in SHARED_JS | Strength | Preserved

Finding P4-02 — runWorkspaceSync + resumeActiveSyncIfAny | Strength | Preserved

Finding P4-03 — Dashboard onboarding duplicate poll | Low | Not fixed

Local pollSyncJob in dashboardPage.ts:1800-1811.

Finding P4-04 — Status enum mismatch (RUNNING / IN_PROGRESS) | Medium | Not fixed

layout.ts:892 and dashboardPage.ts:1788 still check non-schema statuses alongside PENDING/PROCESSING.

Finding P4-05 — Null-safe rendering (post-885f009) | Strength | Preserved

Finding P4-06 — Token decrypt banner | Strength | Preserved

Now hits cached endpoint (server.ts:1328 !' getCachedWorkspaceTokenHealth).

Finding P4-07 — Token health checks primary account only | Medium | Unchanged

Finding P4-08 — CDN / Meta thumbnail fallback | Strength | Preserved

Finding P4-09 — Meta payload edge cases in UI | Medium | Unchanged

Video thumbnail gap when thumbnail_url absent.

Finding P4-10 — friendlyApiError mapping | Strength | Preserved

Finding P4-11 — Dashboard refresh interval + visibility pause | Low | Preserved

Finding P4-12 — Chart.js CDN dependency | Medium | Unchanged

Pillar 5 — Security & Performance

5.1 Security

Finding P5-01 — JWT + tokenVersion revocation | Strength | Preserved

Finding P5-02 — CORS defaults permissive when ALLOWED_ORIGINS empty | High | Not fixed

server.ts:270 still reads env directly; no production fail-fast in config.ts.

Finding P5-03 — CSP allows unsafe-inline scripts | Medium | Unchanged

Finding P5-04 — TLS verification disabled for external DB | High | Not fixed

serve.ts:68, getDashboard.ts:66 — rejectUnauthorized: false unchanged.

Finding P5-05 — Rate limiting in-memory only | Medium | Not fixed

Comment at server.ts:145 explicitly states single-instance.

Finding P5-06 — Platform admin via env email list | Medium | Unchanged

Finding P5-07 — Token encryption AES-256-GCM | Strength | Preserved

Finding P5-08 — AI context sanitization | Medium | Unchanged

5.2 Performance & indexes

Finding P5-09 — Missing index: AdAccount.lastSyncedAt | High | Not fixed

Schema still only @@index([workspaceId]) on ad_accounts; no migration since V1.

Finding P5-10 — Missing index: AdAccount.tokenExpiresAt | High | Not fixed

refreshMetaTokens.ts query unchanged; no composite index added.

Finding P5-11 — Meta external IDs for webhook lookup | Medium | OK (unchanged)

Unique (platform, externalAccountId) sufficient.

Finding P5-12 — SyncJob polling index | Strength | Preserved

Finding P5-13 — Raw insights growth | Medium | Unchanged

No partial index on fetchedAt for prune query.

Finding P5-14 — Connection pool defaults (max 10 implicit) | Medium | Not fixed

serve.ts:69-76 — no max, idleTimeoutMillis configured. BullMQ concurrency (12) can exceed pool default when enabled.

Finding P5-15 — getDashboard stage timeout | Strength | Preserved

Finding P5-16 — Memory: interval timers / OAuth session prune | Low | Unchanged

Finding P5-17 — Platform stats cache per-instance | Low | Unchanged

Finding P5-18 — NEW: Dual Redis TCP connections when BullMQ enabled | Low

App singleton (lib/redis.ts) plus BullMQ dedicated client (lib/queue.ts:81-92) — intentional per BullMQ ioredis requirements; doubles connection count to managed Redis.

Cross-Cutting Observations

Environment variables (delta)

Variable | In config.ts (V2) | Default | Notes

REDIS_URL | Yes (warn if unset) | unset | Gates Redis features

BULLMQ_ENABLED | Yes | false | Queue routing

WEBHOOK_REDIS_DEBOUNCE_ENABLED | Yes | false | Cluster debounce

ALLOWED_ORIGINS | No | — | Still direct process.env in server

STRIPE_*, ANTHROPIC_API_KEY, PUBLIC_APP_URL | Partial / No | — | Unchanged from V1

Test / ops tooling (delta)

Artifact | Purpose

scripts/test-redis-scaling-drill.ts | D1–D5 Redis fallback/latency drills (e6ef331)

scripts/queue-stats.ts | Live BullMQ queue stats CLI (32cd337)

WORKSPACE_ISOLATION_CHECKLIST.md | Phase 6a tenant-boundary audit

Still no automated integration tests for advisory locks, webhook HMAC, SyncJob lifecycle, or OAuth DB roundtrip.

Workers extraction status

BullMQ Phase 3-a runs workers in API process. Separate worker dyno (Phase 3-b) noted in comments only (workers/queue/index.ts:8-9). Auto-sync, token refresh, prune, rollups remain in serve.ts regardless of BullMQ flag.

Prioritized Recommendations (V1 list — status only)

| V1 action | V2 status

R1 | Advisory lock strategy for sync() / auto-sync | Not fixed — sync() unchanged; auto-sync still calls sync()

R2 | Persist OAuth post-callback session | Not fixed — oauthSessions Map remains

R3 | Indexes on tokenExpiresAt, lastSyncedAt | Not fixed — no schema migration

R4 | Configure pg.Pool max + timeouts | Not fixed

R5 | ALLOWED_ORIGINS + config fail-fast | Not fixed

R6 | Job queue extraction | Partially fixed — BullMQ behind flag; co-located; auto-sync excluded

R7		Chunk \$transaction in upsertMany		Not fixed
R8		Split server.ts		Not fixed — file grew
R9		Centralize Meta error code helpers		Not fixed
R10		Align getAccount() primary selection		Not fixed
R11		Reduce any usage		Not fixed — count 31
R12		Deduplicate dashboard pollSyncJob		Not fixed
R13		TLS verify-full for DATABASE_URL		Not fixed
R14		Integration tests		Not fixed — drill script added, not integration tests
R15		Vendor Chart.js		Not fixed

Master-Level Verdict — Biggest Risks (Second Pass)

Top 3 Critical / High Headlines

1. Session advisory locks on pooled connections — auto-sync path still exposed — sync() lacks unlock_all preflight; serve.ts auto-sync unchanged. Horizontal-scaling commits did not touch syncAccount.sync() or auto-sync routing.
1. Horizontal-scaling infrastructure inactive at defaults + incomplete when enabled — Redis/BullMQ/debounce flags default off. When enabled, workers share API process and pool; auto-sync and OAuth sessions remain single-instance assumptions.
1. Multi-instance statefulness (OAuth sessions, rate limits) persists — Redis mitigates webhook debounce herd and token-health decrypt herd only when configured; OAuth completion and rate limits still in-memory.

Architectural maturity scorecard (second pass)

Area		V1 Grade		V2 Grade		Delta notes
Domain layering		A-		A-		Preserved; initialSync.ts extraction positive
Data integrity (ETL)		B+		B+		Hijack guard improves connect integrity
Concurrency		C		C		BullMQ optional; lock semantics unchanged on auto-sync
API security (webhooks)		A-		A-		Durable enqueue when BullMQ on
UI resilience		B+		B+		No UI changes in branch delta
Ops readiness		C+		B-		Redis drill, queue stats, isolation checklist added
Scale readiness		D+		C-		Foundation laid; defaults and gaps limit readiness

Final statement

The feat/horizontal-scaling branch demonstrates deliberate, flag-gated progress toward multi-instance operation: graceful Redis degradation, BullMQ with fallback, cross-workspace connect guard, and ops drill scripts. The production-default codebase behavior matches the first-pass audit for the three headline risks. Enabling flags without completing R1–R5 and OAuth session persistence leaves known gaps partially papered over.

Appendix A — Key file reference map (delta)

File		Role (new or changed)
src/lib/redis.ts		Optional Redis singleton + withRedis fallback
src/lib/queue.ts		BullMQ queues + dedicated ioredis + enqueueOrFallback
src/lib/initialSync.ts		Extracted initial backfill + queue wiring
src/services/cachedTokenHealth.ts		60s read-through token-health cache
src/workers/queue/*		Four BullMQ processors (one scaffolded/unused producer)
scripts/test-redis-scaling-drill.ts		Redis scaling drill
scripts/queue-stats.ts		Queue monitoring CLI
WORKSPACE_ISOLATION_CHECKLIST.md		Phase 6a tenant isolation audit

Appendix B — Feature flag matrix

REDIS_URL unset	!	' all Redis features !' in-process fallback
REDIS_URL set	!	' token-health cache always attempts Redis
WEBHOOK_REDIS_DEBOUNCE_ENABLED=true	!	' SET NX EX debounce (needs Redis)
BULLMQ_ENABLED=true	!	' enqueueOrFallback prefers queues; workers in serve.ts
Both flags off	!	' byte-identical background semantics to pre-64f080e

Appendix C — Audit tooling

- PDF generation: `npx tsx scripts/compileMasterAuditPdf.ts --input ADLYTIC_MASTER_ARCHITECT_AUDIT_2026_V2.md`
- Comparison doc: `ADLYTIC_AUDIT_COMPARISON_V1_V2.md`

End of ADLYTIC_MASTER_ARCHITECT_AUDIT_2026 — Second Pass

